

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

Password Mutations

Many people create their passwords according to **simplicity instead of security**. To eliminate this human weakness that often compromises security measures, password policies can be created on all systems that determine how a password should look. This means that the system recognizes whether the password contains capital letters, special characters, and numbers. In addition, most password policies require a minimum length of eight characters in a password, including at least one of the above specifications.

In the previous sections, we guessed very simple passwords, but it becomes much more difficult to adapt this to systems that apply password policies that force the creation of more complex passwords.

Unfortunately, the tendency for users to create weak passwords also occurs despite the existence of password policies. Most people/employees follow the same rules when creating more complex passwords. Passwords are often created closely related to the service used. This means that many employees often select passwords that can have the company's name in the passwords. A person's preferences and interests also play a significant role. These can be pets, friends, sports, hobbies, and many other elements of life. **OSINT** information gathering can be very helpful for finding out more about a user's preferences and may assist with password guessing. More information about OSINT can be found in the [OSINT: Corporate Recon module](#). Commonly, users use the following additions for their password to fit the most common password policies:

Description	Password Syntax
First letter is uppercase.	Password
Adding numbers.	Password123
Adding year.	Password2022
Adding month.	Password02
Last character is an exclamation mark.	Password2022!
Adding special characters.	P@ssw0rd2022!

Considering that many people want to keep their passwords as simple as possible despite password policies, we can create rules for generating weak passwords. Based on statistics provided by [WPengine](#), most password lengths are **not longer** than **ten** characters. So what we can do is to pick specific terms that are at least **five** characters long and seem to be the most familiar to the users, such as the names of their pets, hobbies, preferences, and other interests. If the user chooses a single word (such as the current month), adds the **current year**, followed by a special character, at the end of their password, we would reach the **ten-character** password requirement. Considering that most companies require regular password changes, a user can modify their password by just changing the name of a month or a single number, etc. Let's use a simple example to create a password list with only one entry.

Password List

Password Mutations
<code>dbcypn@htb[/htb]\$ cat password.list</code>
<code>password</code>

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

custom wordlists. To become more familiar with Hashcat and discover the full potential of this tool, we recommend the module

[Cracking Passwords with Hashcat](#). Hashcat uses a specific syntax for defining characters and words and how they can be modified.

The complete list of this syntax can be found in the official [documentation](#) of Hashcat. However, the ones listed below are enough for us to understand how Hashcat mutates words.

Function	Description
:	Do nothing.
l	Lowercase all letters.
u	Uppercase all letters.
c	Capitalize the first letter and lowercase others.
sXY	Replace all instances of X with Y.
\$!	Add the exclamation character at the end.

Each rule is written on a new line which determines how the word should be mutated. If we write the functions shown above into a file and consider the aspects mentioned, this file can then look like this:

Hashcat Rule File

```
                                Password Mutations

dbcyph0n@htb[/htb]$ cat custom.rule

:
c
so0
c so0
sa@
c sa@
c sa@ so0
$!
$! c
$! so0
$! sa@
$! c so0
$! c sa@
$! so0 sa@
$! c so0 sa@
```

Hashcat will apply the rules of `custom.rule` for each word in `password.list` and store the mutated version in our `mut_password.list` accordingly. Thus, one word will result in fifteen mutated words in this case.

Generating Rule-based Wordlist

```
                                Password Mutations

dbcyph0n@htb[/htb]$ hashcat --force password.list -r custom.rule --stdout | sort -u > mut_password.list
dbcyph0n@htb[/htb]$ cat mut_password.list

password
Password
passw0rd
Passw0rd
```



Scheduled Maintenance on US Academy VPNs 16/5/2024

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

```
passw0rd!  
p@ssword!  
Passw0rd!  
P@ssword!  
p@ssw0rd!  
P@ssw0rd!
```

Hashcat and John come with pre-built rule lists that we can use for our password generating and cracking purposes. One of the most used rules is `best64.rule`, which can often lead to good results. It is important to note that password cracking and the creation of custom wordlists is a guessing game in most cases. We can narrow this down and perform more targeted guessing if we have information about the password policy and take into account the company name, geographical region, industry, and other topics/ words that users may select from to create their passwords. Exceptions are, of course, cases where passwords are leaked and found.

Hashcat Existing Rules

Password Mutations

```
dbcypthon@htb[/htb]$ ls /usr/share/hashcat/rules/  
  
best64.rule           specific.rule  
combinator.rule       T0X1C-insert_00-99_1950-2050_toprules_0_F.rule  
d3ad0ne.rule          T0X1C-insert_space_and_special_0_F.rule  
dive.rule             T0X1C-insert_top_100_passwords_1_G.rule  
generated2.rule       T0X1C.rule  
generated.rule        T0X1Cv1.rule  
hybrid               toggles1.rule  
Incisive-leetspeak.rule toggles2.rule  
InsidePro-HashManager.rule toggles3.rule  
InsidePro-PasswordsPro.rule toggles4.rule  
leetspeak.rule        toggles5.rule  
oscommerce.rule       unix-ninja-leetspeak.rule  
rockyou-30000.rule
```

We can now use another tool called `CeWL` to scan potential words from the company's website and save them in a separate list. We can then combine this list with the desired rules and create a customized password list that has a higher probability of guessing a correct password. We specify some parameters, like the depth to spider (`-d`), the minimum length of the word (`-m`), the storage of the found words in lowercase (`--lowercase`), as well as the file where we want to store the results (`-w`).

Generating Wordlists Using CeWL

Password Mutations

```
dbcypthon@htb[/htb]$ cewl https://www.inlanefreight.com -d 4 -m 6 --lowercase -w inlane.wordlist  
dbcypthon@htb[/htb]$ wc -l inlane.wordlist  
  
326
```

VPN Servers

Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

[DOWNLOAD VPN CONNECTION FILE](#)**Connect to Pwnbox**

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

61ms ▼

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

**Questions**

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)



Cheat Sheet



Download VPN
Connection File



Create a mutated wordlist using the files in the ZIP file under "Resources" in the top right corner of this section. Use this wordlist to brute force the password for the user "sam". Once successful, log in with SSH and submit the contents of the flag.txt file as your answer.

Submit your answer here...

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

[< Previous](#)[Next >](#)[📄 Cheat Sheet](#)[📖 Resources](#)[? Go to Questions](#)**Table of Contents****Introduction**

Theory of Protection	✓
Credential Storage	✓
John The Ripper	✓

Remote Password Attacks

📦 Network Services	✓
📦 Password Mutations	
📦 Password Reuse / Default Passwords	

Windows Local Password Attacks

📦 Attacking SAM	
📦 Attacking LSASS	
📦 Attacking Active Directory & NTDS.dit	
📦 Credential Hunting in Windows	

Linux Local Password Attacks

📦 Credential Hunting in Linux	
📦 Passwd, Shadow & Opaswd	

Windows Lateral Movement

📦 Pass the Hash (PtH)	
📦 Pass the Ticket (PtT) from Windows	
📦 Pass the Ticket (PtT) from Linux	

Cracking Files

📦 Protected Files	
📦 Protected Archives	

Password Management

Password Policies	
Password Managers	

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.



Password Attacks Lab - Hard

My Workstation

O F F L I N E

▶ Start Instance

∞ / 1 spawns left